

1. Grundbegriffe und Definitionen

- **Compliance:** Die Einhaltung von allgemeinen Gesetzen sowie von selbst gesetzten Regeln innerhalb eines Unternehmens (z. B. Richtlinien zur Annahme von Geschenken), um rechtliche Verstöße und Reputationsschäden zu vermeiden.
- **Datenschutzbeauftragter:** Ein Unternehmen muss einen Datenschutzbeauftragten bestellen, um die Einhaltung der Gesetze zum Schutz personenbezogener Daten sicherzustellen.
- **Briefgeheimnis:** Der Inhalt von E-Mails unterliegt rechtlichem Schutz; Administratoren oder Spam-Filter dürfen Inhalte nur unter streng definierten Bedingungen untersuchen.

2. Zentrale Prinzipien der DSGVO

Bei der Verarbeitung personenbezogener Daten (z. B. Videoüberwachung oder Kundendatenbanken) müssen folgende Grundsätze beachtet werden:

- **Zweckbindung:** Daten dürfen nur für den Zweck verarbeitet werden, für den sie ursprünglich erhoben wurden.
- **Datenminimierung (Datensparsamkeit):** Es sollten nur so viele Informationen wie nötig erhoben werden.
- **Löschfristen:** Personenbezogene Daten müssen nach Ablauf der gesetzlichen oder betrieblichen Aufbewahrungsfristen gelöscht werden.
- **Persönlichkeitsrecht:** Die Überwachung oder Datenverarbeitung darf die Rechte der betroffenen Personen nicht unverhältnismäßig einschränken.

3. Anonymisierung vs. Pseudonymisierung

Zur Wahrung des Datenschutzes werden unterschiedliche Verfahren zur Unkenntlichmachung von Daten eingesetzt:

- **Pseudonymisierung:** Ersetzen von Identifikationsmerkmalen (z. B. Name) durch künstliche Kennungen (Identifikatoren). Die Daten sind weiterhin für eine Analyse nutzbar, und der Prozess ist **reversibel** (umkehrbar), falls die Zuordnungstabelle vorliegt.
- **Anonymisierung:** Die Daten werden so verändert, dass sie keiner natürlichen Person mehr zugeordnet werden können. Dieser Prozess ist **unwiderruflich** (nicht reversibel).

4. Technisch-organisatorische Maßnahmen (TOM)

TOMs dienen dem Schutz der Daten vor Missbrauch oder Verlust. Sie werden in verschiedene Kontrollbereiche unterteilt:

Bereich	Zielsetzung	Beispiele aus der Prüfung
Zutrittskontrolle	Unbefugten den physischen Zutritt verwehren.	Alarmanlagen, RFID-Chipkarten für Gebäude, Besucheranmeldung am Empfang.
Zugangskontrolle	Unbefugte Nutzung von Systemen verhindern.	Benutzeridentifikation am PC (z. B. Biometrie), Passwortregeln.
Zugriffskontrolle	Unbefugtes Lesen, Kopieren oder Ändern von Daten verhindern.	Berechtigungskonzepte auf Dateiebene, Verschlüsselung von Datenträgern, Erstellung von Benutzerprofilen.

5. Moderne Sicherheitsprinzipien

In aktuellen Prüfungsszenarien (z. B. Sommer 2025) werden zwei Konzepte besonders hervorgehoben:

- **Least-Privilege-Prinzip:** Benutzern und Systemen werden nur die **minimal notwendigen Rechte** eingeräumt, die für ihre Aufgabe zwingend erforderlich sind.
- **Zero-Trust-Prinzip:** Keinem Gerät oder Benutzer wird standardmäßig vertraut, unabhängig davon, ob sich dieser innerhalb oder außerhalb des Firmennetzwerks befindet; jede Anfrage muss erneut verifiziert werden.

6. Verhalten bei Datenschutzvorfällen

Kommt es zu einem Sicherheitsvorfall (z. B. Ransomware-Angriff oder Versand von Kundendaten an falsche Empfänger), müssen nach DSGVO bestimmte Kriterien geprüft werden, um zu entscheiden, ob eine **Informationspflicht** gegenüber den Behörden oder Betroffenen besteht.

- **Maßnahmen nach Fehlversand:** Sofortige Einleitung von Gegenmaßnahmen (z. B. Rückruf der Mail, falls möglich), Dokumentation des Vorfalls und ggf. Meldung an den Datenschutzbeauftragten.
- **System-Härtung:** Zur Prävention sollten Server nach der Installation "gehärtet" werden (z. B. Deaktivierung unnötiger Dienste, Nutzung von Secure Boot und TPM 2.0).